GitHub Copilot Autofix for CodeQL Code Scanning Alerts

Question: During a pull request check on GitHub.com, GitHub Advanced Security CodeQL code scanning flags a SQL injection vulnerability across two files. How does **Copilot Autofix** assist the developer in resolving the alert?

A. It silently commits and merges the security patch into the default branch without pull request review.

B. It generates a natural-language explanation of the vulnerability alongside a proposed multi-file code diff (including dependency updates if needed) that the developer can review and commit. **[CORRECT ANSWER]**

C. It automatically adds the vulnerable file path to Content Exclusions so future scans ignore the alert.

D. It downgrades the CodeQL alert severity from High to Note so CI checks pass.

Explanation & Exam Rationale

GitHub Copilot Autofix combines GitHub's CodeQL static analysis engine with Copilot's LLM capabilities to remediate code scanning alerts directly inside pull requests and the repository's *Security* tab. It analyzes the vulnerability data-flow trace, explains the root cause, and proposes a ready-to-review patch across one or multiple files—while keeping a human developer in control of accepting and committing the fix.

Capability	Copilot Autofix (GitHub.com)	`/fix` Slash Command (IDE Chat)
Trigger Context	CodeQL code scanning alerts in PRs & Security tab	Compiler diagnostics, linter errors, or selected code in IDE
Scope	Full vulnerability data-flow path (can span multiple files & dependencies)	Active editor selection or current file diagnostics
Human Oversight	Developer reviews diff, edits if needed, and clicks *Commit fix*	Developer reviews inline diff and clicks *Accept* or *Discard*

Key Exam Takeaway: Copilot Autofix never commits changes autonomously—every generated security patch requires explicit developer review and approval before being committed to the branch.